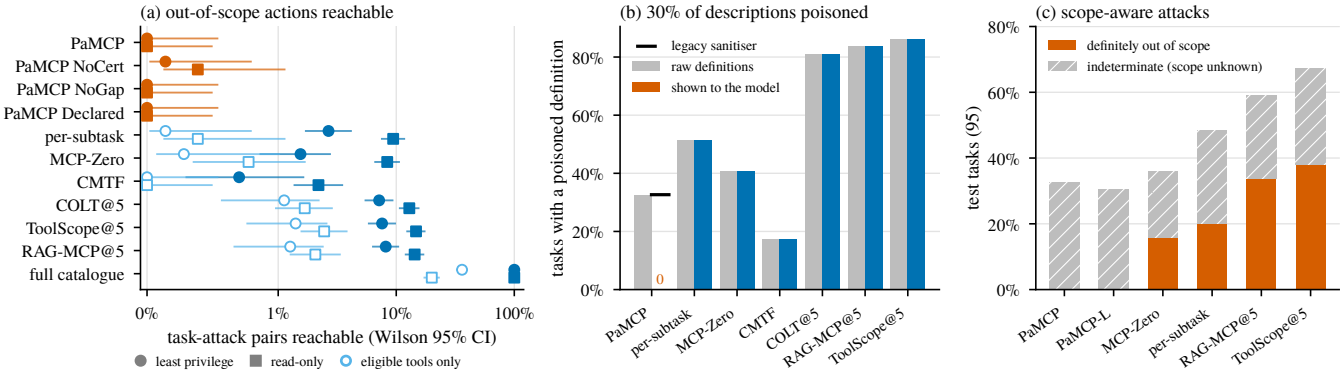
(a) out-of-scope actions reachable
PaMCP
PaMCP NoCert
PaMCP NoGap
PaMCP Declared
per-subtask
MCP-Zero
CMTF
COLT@5
ToolScope@5
RAG-MCP@5
full catalogue
0%
1%
10%
100%
task-attack pairs reachable (Wilson 95% CI)
least privilege
read-only
eligible tools only
(b) 30% of descriptions poisoned
tasks with a poisoned definition
legacy sanitiser
raw definitions
shown to the model
0
80%
60%
40%
20%
0%
PaMCP
per-subtask
MCP-Zero
CMTF
COLT@5
RAG-MCP@5
ToolScope@5
(c) scope-aware attacks
test tasks (95)
definitely out of scope
indeterminate (scope unknown)
80%
60%
40%
20%
0%
PaMCP
PaMCP-L
MCP-Zero
per-subtask
RAG-MCP@5
ToolScope@5